

# Drilldown

Analyst: Benjamin Liu

Date: 6/3/2026

---

## Executive Summary

On August 10, 2016, Threat hunting team discovered suspicious connection to EC2 instances which is out of normal business pattern. The attacker first gained unauthorized access to the Joomla administration panel via brute-force credential attacks originating from 23.22.63.114. In Joomla/administrator/ path, subsequent investigation revealed two malicious payloads uploaded to the web server with a HTTP POST quest from the attacker, including a trojan software which is used to hide malicious behaviors, such as loader and backdoor, and a php file to build webshell. Web server we1149srv is the only infected machine. There is no further evidence to prove that exfiltration and lateral movement happened. Mapping to MitreAttack the attack chain involves C2, credential access, stealth, execution. Immediate remediation actions include isolating the affected host, blocking attacker IP addresses at the firewall, removing malicious payloads, and resetting Joomla administrator credentials. Short- and long-term controls are detailed in the Remediation section.

## Senario

Your organization doesn't use Amazon Web Services, so when a Threat Hunter starts seeing connections to multiple EC2 instances, it's time to start hunting to understand what happened, so the information can be passed to the incident response team, and indicators can be gathered for intelligence sharing.

## Timeline

| TIME                               | TYPE                           | IOCs                                                                                                                                                      | OPERATOR                                         |
|------------------------------------|--------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------|
| 08-10-2016@15:52:45                | Virus detected;<br>upload file | virus="W32/Swrort.C!tr" ;<br>dtype="Virus" ;<br>ref="http[:]//www[.]fortinet[.]com/ve?vn=W32%2FSwrort.C%21tr";<br>virusid=1706341 ; filename<br>3791.exe; | Alarm<br>from:<br>fortigate_utm                  |
| 08-10-2016@21:45:21 ~ 21:46:51.394 | Brute force                    | username=admin&0960d493674eb04861bd64da9b662118=1&task=login&return=aW5kZXgucGhw&option=com_login&passwd=arthur; (100+)<br>Http-method: POST              | Attacker<br>SrcIP:<br>23[.]22[.]63[.]114         |
| 08-10-2016@21:50:31                | upload file                    | URI:<br>"/joomla/administrator/index.php?option=com_installer&view=install "<br>HTTP method: POST<br>filename: agent.php                                  | Attacker<br>src_ip :<br>40[.]80[.]148[.]42:49474 |
| 08-10-2016@21:50:31 ~ 22:21:34     | HTTP GET request               | refer :<br>"http[:]//www[.]google[.]ml/url?sa=t&rct=j&q=39.18&source=web&cd=077&ved=4VPTJIOHX&url=39&ei=315GkrmqofZQiDalczaD                              | Attacker<br>src_ip :<br>40[.]80[.]148[.]42       |

|                                   |                  |                                                                                                                                                                                                                                  |                                          |
|-----------------------------------|------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------|
|                                   |                  | E0&usg=zg0vLgdcefYdxMSA41Q<br>l4HLcZiS9M5VWav" ; (100+)<br>request :GET /joomla/agent.php<br>HTTP/1.1;                                                                                                                           |                                          |
| 08-10-2016@21:52:<br>47           | upload files     | reference:<br>"http[:]//imreallynotbatman[.]com/joomla/administrator/index[.]php?option=com_extplorer&tmpl=component;<br>part_filename":["3791.exe","agent.php"];<br>Http method: POST<br>dstip:192[.]168[.]250[.]70             | Attacker<br>SrcIP:40[.]80[.]148[.]42     |
| 08-10-2016@21:55:<br>22~ 22:21:34 | HTTP Get request | refer:<br>"http[:]//www[.]google[.]ge/url?s<br>a=t&rct=j&source=web&cd=99<br>9&ved=422S6hzhfP&ei=es4FIEBQ<br>gF69AxYiTkOxs6&usg=f95vb7hQ<br>YhuEt0MHm69toQuv45ifXrle1K "<br>(194+)<br>request :GET /joomla/agent.php<br>HTTP/1.1 | Attacker<br>SrcIP:<br>23[.]22[.]63[.]114 |
| 08-10-2016@21:56:<br>18~ 22:08:13 | Execution        | cmd.exe /c "3791.exe 2>&1                                                                                                                                                                                                        | NT AUTHORITY\IUSR                        |

## IOCs

- Virus="W32/Swrort.C!tr" ; dtype="Virus" ;  
  
ref="http[:]//www[.]fortinet[.]com/ve?vn=W32%2FSwrort.C%21tr"; virusid=1706341  
  
;
- C:\inetpub\wwwroot\joomla\3791.exe on host we1149srv
- Forge reference:  
  
http[:]//www[.]google[.]ge/url?sa=t&rct=j&source=web&cd=999&ved=422S6hzhfP  
  
&ei=es4FIEBQgF69AxYiTkOxs6&usg=f95vb7hQYhuEt0MHm69toQuv45ifXrle1K [  
  
Forged domain of Google, and attached random arguments to disguise as normal  
  
user traffic to avoid IDS/WAF filter.]
- 3791.exe was executed by account "NT AUTHORITY\IUSR" with commandline  
  
"cmd.exe /c "3791.exe 2>&1"
- Intranet IP address of the victim server is 192[.]168[.]250[.]70, Extranet IP address of  
  
the victime server is 71[.]39[.]18[.]126
- Attacker's ip address:
  - 40[.]80[.]148[.]42
  - 23[.]22[.]63[.]114, associated with AWS service houstname :  
  
ec2-23-22-63-114.compute-1.amazonaws.com
- Initial access url : /joomla/administrator/index.php
- UserAgent used by attacker to upload malicious files: Mozilla/5.0 (Windows NT 6.1;  
  
WOW64; Trident/7.0; rv:11.0) like Gecko

- Hash of 3791.exe:

EC78C938D8453739CA2A370B9C275971EC46CAF6E479DE2B2D04E97CC47FA45D

- " GET /joomla/agent.php" requested from both 23[.]22[.]63[.]114 and 40[.]80[.]148[.]42
- Victim web Server
  - Private IP: 192[.]168[.]250[.]70
  - Public IP : 71[.]39[.]18[.]126
  - Hostname : we1149srv.waynecorpinc.local
  - Host website domain: imreallynotbatman.com

## Remediation Suggestions

- For immediate action:
  - Taking the Site offline and setting white-list for access..
  - Limiting the connection from IP address 40[.]80[.]148[.]42 and 23[.]22[.]63[.]114 at firewall and web proxy.
  - Force logout of all accounts and reset administrator and database credentials at the control panel of Joomla.
  - Removing the malicious executable 3791.exe and agent.php from C:\inetpub\wwwroot\joomla\ on host we1149srv.
- For short-term plan:

- Limit access to the Joomla administration panel to only internal networks.
- Perform vulnerability scans; Patch the vulnerabilities of Joomla ; Upgrade the Joomla software and related plugins.
- Create a complete forensic image of the we1149srv server.
- For Long-term plan:
  - Configuring Suricata to against the malicious HTTP request from AWS
  - building unauthorized cloud service usage monitoring baseline
  - scheduling periodic web penetration test on the web sever

#### MITRE ATTACK Mapping

| Technique ID | Note                  | IOCs                                                                                                                                                      |
|--------------|-----------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------|
| T1105        | Ingress tool transfer | "http[:]//imreallynotbatman[.]com/joomla/administrator/index[.]php?option=com_extplorer&tmpl=component;part_filename":["3791.exe","agent.php"];           |
| T1110        | Brute Force           | username=admin&0960d493674eb04861bd64da9b662118=1&task=login&return=aW5kZXgucGhw&option=com_login&passwd=arthur; (100+)<br>Http-method: POST              |
| T1036        | Masquerading          | http[:]//www[.]google[.]ml/url?sa=t&rct=j&q=39.18&source=web&cd=077&ved=4VPTJlOHX&url=39&ei=315GkrmqofZQidAlczaDE0&usg=zg0vLgdcefYdxMSA41Ql4HLcZiS9M5VWav |

|           |                                                        |                                                                 |
|-----------|--------------------------------------------------------|-----------------------------------------------------------------|
| T1059.003 | command and scripting interpreter:windows command line | cmd.exe /c "3791.exe 2>&1                                       |
| T1078     | Valid Accounts                                         | Joomla administrator account                                    |
| T1071     | Application Layer protocol                             | Attacker sent Post request to agent.php and run cmd commandline |

### Investigation Screenshot

- **Amazon EC2** (Elastic Compute Cloud) is a core AWS service that lets you rent virtual computers (instances) to run applications in the cloud.
- **Domain of AWS** : amazonaws.com
- **Subdomain of EC2**: compute.amazonaws.com

**Question 1) WayneCorpInc doesn't use Amazon Web Service for cloud hosting, so when a threat hunting discovered outbound connections to EC2 instances they immediately began to drilldown into this activity so they can provide as much context for the Incident Response Team as possible. Using Sysmon logs, how many destination hostnames are found? (Format: # Destination EC2s) (3 points)**

3

Correct! ✓



```

a dvc_nt_host 100+
# event_id 100+
# EventCode 1
a EventData_Xml 100+
# EventID 1
# EventRecordID 100+
a eventtype 2
a Guld 1
# id 100+
a Image 5
a index 1
a Initiated 2
a Keywords 1
# Level 1
# linecount 2
a Name 1
# Opcode 1
a ProcessGuid 7
# ProcessId 7
a ProcessID 4

```

### Image

5 Values, 100% of events

Selected

**Reports**

[Top values](#)
[Top values by time](#)
[Rare values](#)

[Events with this field](#)

| Values                                      | Count | %       |
|---------------------------------------------|-------|---------|
| System                                      | 1,430 | 87.195% |
| C:\Windows\System32\svchost.exe             | 203   | 12.378% |
| C:\Program Files (x86)\PHP\v5.5\php-cgi.exe | 3     | 0.183%  |
| C:\Windows\System32\dns.exe                 | 3     | 0.183%  |
| C:\inetpub\wwwroot\joomla\3791.exe          | 1     | 0.061%  |

From the field image, I find a suspicious executable named 3791.exe.

65

Community Score

65/71 security vendors flagged this file as malicious

ec78c938d8453739ca2a370b9c275971ec46caf6e479de2b2d04e9cc47fa45d

ab.exe

Size 72.07 KB

Last Analysis Date 2 months ago

[peexe](#)
[checks-user-input](#)
[idle](#)
[detect-debug-environment](#)
[overlay](#)

[DETECTION](#)
[DETAILS](#)
[RELATIONS](#)
[BEHAVIOR](#)
[COMMUNITY 24](#)

Join our Community and enjoy additional community insights and crowdsourced detections, plus an API key to automate checks.

[Code insights](#)

This binary is a trojanized version of the ApacheBench (ab.exe) utility. While it contains legitimate strings and metadata related to Apache performance testing (e.g., 'Requests per second', 'Zeus Technology Ltd'), the underlying code structure reveals malicious obfuscation and payload delivery mechanisms. The entry point (start at 0x400000) consists of a sequence of BCD instructions (AAA, DAA, AAS, DAS) which are almost exclusively used in manual assembly obfuscation or shellcode. Decompile of sub\_40abf0 and sub\_40acd7 shows manual decryption loops using XOR (0x0E) and obfuscated calls to LoadLibraryA. These techniques are used to hide malicious behavior, such as a loader or backdoor, within a legitimate-looking benchmarking tool.

[Popular threat label](#)
[trojan.sswort/rozema](#)

[Threat categories](#)
[trojan](#)

[Family labels](#)
[sswort](#)
[rozema](#)
[cryptz](#)

[Security vendors' analysis](#)

| Vendor              | Analysis                       | Vendor           | Analysis                   |
|---------------------|--------------------------------|------------------|----------------------------|
| Acronis (Static ML) | Suspicious                     | AhnLab-V3        | Trojan.Win32.Shell.R1283   |
| Alibaba             | Trojan.Win32/CobaltStrike.5c89 | AliCloud         | Backdoor.Win/meterpreter.A |
| Antiy-AVL           | Trojan.Win32.Rozema            | Arcabit          | Trojan.CryptZ.Marta.1.Gen  |
| Arctic Wolf         | Unsafe                         | Avast            | Win32.SwPatch [Wrm]        |
| AVG                 | Win32.SwPatch [Wrm]            | Avira (no cloud) | TR/Patched.Gen2            |

This malicious executable is a trojan and used to hide behaviors, such as loader and backdoor within a legitimate-looking benchmarking tool.

**Question 4) What is the hostname and internal IP address of the system that initiated this connection? (Format: Hostname, X.X.X.X) (3 points)**

we1149srv.waynecorpinc.local, 192.168.250.

Correct! ✓

Search | Splunk 8.2.3 — Mozilla Firefox

Hide Fields All Fields List Format 20 Per Page

Time Event

EventRecordID 1  
eventtype 2  
id 1  
Image 1  
index 1  
initiated 1  
Keywords 1  
Level 1  
linecount 1  
Name 1  
Opcode 1  
ProcessGuid 1  
ProcessID 1  
ProcessName 1  
Protocol 1  
punct 1  
RecordNumber 1  
signature\_id 1  
SourceHostname 1  
SourceIP 1  
SourceIPV6 1  
SourcePort 1  
splunk\_server 1  
System\_Props\_Xml 1  
SystemTime 1  
tag 1  
tag:eventtype 1  
Task 1  
ThreadID 1  
User 1  
user\_id 1  
UserID 1  
Uptime 1  
vendor\_product 1  
Version 1

+ Extract New Fields

DestinationIPV6 false  
DestinationPort 3791  
EventCode 3  
EventData\_Xml <Data Name="Uptime">2016-08-10 12:53:32.270</Data><Data Name="ProcessGuid">(E500B0EA-A302-57AB-0000-00108D65C301)</Data><Data Name="ProcessID">3880</Data><Data Name="Image">C:\inetpub\wwwroot\joomla\3791.exe</Data><Data Name="User">NT AUTHORITY\USER</Data><Data Name="Protocol">tcp</Data><Data Name="Initiated">false</Data><Data Name="SourceIPV6">false</Data><Data Name="SourceIP">192.168.250.70</Data><Data Name="SourceHostname">we1149srv.waynecorpinc.local</Data><Data Name="SourcePort">63394</Data><Data Name="SourcePortName"></Data><Data Name="DestinationIPV6">false</Data><Data Name="DestinationIP">23.22.63.114</Data><Data Name="DestinationHostname">ec2-23-22-63-114.compute-1.amazonaws.com</Data><Data Name="DestinationPort">3791</Data><Data Name="DestinationPortName"></Data>

EventID 3  
EventRecordID 429000  
Guid [5770385F-C22A-43E0-BF4C-06F5698FBD9]  
Image C:\inetpub\wwwroot\joomla\3791.exe  
Initiated true  
Keywords 0x8000000000000000  
Level 4  
Name 'Microsoft-Windows-Sysmon'  
Opcode 0  
ProcessGuid (E500B0EA-A302-57AB-0000-00108D65C301)  
ProcessID 1296  
ProcessName Microsoft-Windows-Sysmon  
ProcessID 3880  
Protocol tcp  
RecordNumber 429000  
SourceHostname we1149srv.waynecorpinc.local  
SourceIP 192.168.250.70  
SourceIPV6 false  
SourcePort 63394  
SystemTime 2016-08-10T21:56:19.251675500Z  
System\_Props\_Xml <Provider Name="Microsoft-Windows-Sysmon" Guid="{5770385F-C22A-43E0-BF4C-06F5698FBD9}"><EventID>3</EventID><Version>5</Version><Level>4</Level><Task>3</Task><Opcode>0</Opcode><Keywords>0x8000000000000000</Keywords><TimeCreated SystemTime="2016-08-10T21:56:19.251675500Z"></EventRecordID>429000</EventRecordID><Correlation></Execution ProcessID="1296" ThreadID="1394"></Channel>Microsoft-Windows-Sysmon\Operational</Channel><Computer>we1149srv.waynecorpinc.local</Computer><Security UserID">S-1-5-18</Security UserID>

Clicking the 3791.exe in the field image, I got more details about the executable.

**Question 5) What time was this connection event? Use TimeCreated SystemTime (Format: YYYY-MM-DDTHH:MM:SS) (3 points)**

2016-08-10 21:56:19

Correct! ✓

**Question 6) What is the destination hostname and IP address of the AWS EC2 instance? (Format: Hostname, X.X.X.X) (3 points)**

ec2-23-22-63-114.compute-1.amazonaws.com

Correct! ✓

1 \* amazonaws.com source=WinEventLog:Microsoft-Windows-Sysmon\Operational Image=C:\inetpub\wwwroot\joomla\3791.exe

1 event (before 5/28/26 7:04:10.000 PM) No Event Sampling

Events (1) Patterns Statistics Visualization

Format Timeline Zoom Out Zoom to Selection Deselect

1 millisecond per column

List Format 20 Per Page

< Hide Fields All Fields

SELECTED FIELDS

- host 1
- source 1
- sourcetype 1

INTERESTING FIELDS

- Channel 1
- Computer 1
- DestinationHostname 1
- DestinationIp 1
- DestinationIpV6 1
- DestinationPort 1
- dvc 1
- dvc\_n\_host 1
- event\_id 1
- EventCode 1
- EventData\_Xml 1
- EventID 1
- EventRecordID 1
- eventtype 2
- Guid 1
- id 1
- Image 1
- index 1
- initiated 1
- Keywords 1
- Level 1

Event Actions

| Type     | Field               | Value                                                                                                                                                                                                                                                                                                                                                                                                                                                                   | Actions |
|----------|---------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------|
| Selected | host                | we1149srv                                                                                                                                                                                                                                                                                                                                                                                                                                                               |         |
|          | source              | WinEventLog:Microsoft-Windows-Sysmon\Operational                                                                                                                                                                                                                                                                                                                                                                                                                        |         |
|          | sourcetype          | xmlwineventlog                                                                                                                                                                                                                                                                                                                                                                                                                                                          |         |
| Event    | Channel             | Microsoft-Windows-Sysmon\Operational                                                                                                                                                                                                                                                                                                                                                                                                                                    |         |
|          | Computer            | we1149srv.waynecorpinc.local                                                                                                                                                                                                                                                                                                                                                                                                                                            |         |
|          | DestinationHostname | ec2-23-22-63-114.compute-1.amazonaws.com                                                                                                                                                                                                                                                                                                                                                                                                                                |         |
|          | DestinationIp       | 23.22.63.104                                                                                                                                                                                                                                                                                                                                                                                                                                                            |         |
|          | DestinationIpV6     | false                                                                                                                                                                                                                                                                                                                                                                                                                                                                   |         |
|          | DestinationPort     | 3791                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |         |
|          | EventCode           | 3                                                                                                                                                                                                                                                                                                                                                                                                                                                                       |         |
|          | EventData_Xml       | <Data Name="UtcTime">2016-08-10 12:53:32.270</Data><Data Name="ProcessGuid">{E500B0EA-A302-57AB-0000-0010B065C301}</Data><Data Name="ProcessId">3880</Data><Data Name="Image">C:\inetpub\wwwroot\joomla\3791.exe</Data><Data Name="Protocol">tcp</Data><Data Name="SourceIp">192.168.250.70</Data><Data Name="SourceIpV6">false</Data><Data Name="SourcePort">3791</Data><Data Name="DestinationIp">23.22.63.114</Data><Data Name="DestinationPort">3791</Data></Event> |         |

Time of the connection built by 3791.exe at 21:56:19.

**Question 7) Utilize Sysmon logs to find the SHA256 hash of the executable making this connection. What is the hash value? (Format: SHA256 Hash) (5 points)**

**EC78C938D8453739CA2A370B9C275971EC**

**Correct! ✓**

1 \* source=WinEventLog:Microsoft-Windows-Sysmon\Operational Image=C:\inetpub\wwwroot\joomla\3791.exe EventID=1

1 event (before 5/28/26 7:39:14.000 PM) No Event Sampling

Events (1) Patterns Statistics Visualization

Format Timeline Zoom Out Zoom to Selection Deselect

1 millisecond per column

List Format 20 Per Page

< Hide Fields All Fields

SELECTED FIELDS

- host 1
- source 1
- sourcetype 1

INTERESTING FIELDS

- Channel 1
- CommandLine 1
- Computer 1
- CurrentDirectory 1

| i | Time                      | Event                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                           |
|---|---------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| > | 8/10/16<br>9:56:18.000 PM | <Event xmlns="http://schemas.microsoft.com/win/2004/08/events/event"><System><Provider Name="Microsoft-Windows-Sysmon" Guid="{5778385F-C22A-43E8-8F4C-06F5698FBD9}" /><EventID>1</EventID><Version>5</Version><Level>4</Level><Task>5</Task><Opcode>0</Opcode><Keywords>8x8000000000000000</Keywords><TimeCreated SystemTime="2016-08-10T21:56:18.142461706Z" /><EventRecordID>428988</EventRecordID><Correlation></Correlation><Execution ProcessID="1296" ThreadID="1416" /><Channel>Microsoft-Windows-Sysmon\Operational</Channel><Computer>we1149srv.waynecorpinc.local</Computer><Security UserID="S-1-5-18" /></System><EventData><Data Name="UtcTime">2016-08-10 21:56:18.142</Data><Data Name="ProcessGuid">{E500B0EA-A302-57AB-0000-0010B065C301}</Data><Data Name="ProcessId">3880</Data><Data Name="Image">C:\inetpub\wwwroot\joomla\3791.exe</Data><Data Name="CommandLine">3791.exe</Data><Data Name="CurrentDirectory">C:\inetpub\wwwroot\joomla</Data><Data Name="User">NT AUTHORITY\USER</Data><Data Name="Protocol">tcp</Data><Data Name="Initiated">true</Data><Data Name="LoginId">8x3e</Data><Data Name="TerminalSessionId">9</Data><Data Name="IntegrityLevel">High</Data><Data Name="Hashes">SHA1=650F30773240088C3C3E5704450F8F04A3A51_MD5=AE3F5A2953564BC2C2754D12A9A70_SHA256=EC78C938D8453739CA2A370B9C275971EC46CAF6E4790E2B204E37CC47FA45D_1PHASH=481F4788B2C9C21E18B065F52B04C448</Data><Data Name="ParentProcessGuid">{E500B0EA-A302-57AB-0000-0010B065C301}</Data><Data Name="ParentProcessId">2896</Data><Data Name="ParentImage">C:\Windows\SysWow64\cmd.exe</Data><Data Name="ParentCommandLine">cmd.exe /c "3791.exe 28gt;&amp;1"</Data></EventData></Event> |

I searched for the eventID=1 and the 3791.exe. Then I got one item which includes the sha256 hash of 3791.exe.

**Question 8) Search this hash online to find more about its reputation. On the Behaviour tab look at the results for Microsoft Sysinternals. What two IPv4 addresses are listed, that begin with 23.216.? (Format: X.X.X.X, X.X.X.X) (3 points)**

23.216.147.64, 23.216.147.76

Correct! ✓

65 / 71  
Community Score -15

65/71 security vendors flagged this file as malicious

ec78c938d453739ca2a370b9c275971ec46cafe479d62b2d04e97cc47fa45d  
ab.exe

Size: 72.07 KB  
Last Analysis Date: 2 months ago

peexe checks-user-input idle detect-debug-environment overlay

DETECTION DETAILS RELATIONS **BEHAVIOR** COMMUNITY (24)

Join our Community and enjoy additional community insights and crowdsourced detections, plus an API key to automate checks.

☐ Display grouped sandbox reports

| Sandbox                | Verdict   | Score | IPs | Ports | URLs | Scripts | Files | Other |
|------------------------|-----------|-------|-----|-------|------|---------|-------|-------|
| CAPI                   | Malicious | 1     | 0   | 0     | 0    | 0       | 0     | 0     |
| CAPE Sandbox           | Malicious | 1     | 0   | 0     | 0    | 0       | 0     | 8     |
| DAS Security Orcas     | Malicious | 1     | 0   | 0     | 0    | 0       | 0     | 1     |
| Microsoft Sysinternals | Malicious | 99+   | 2   | 0     | 0    | 0       | 0     | 99+   |
| Tencent HABO           | Malicious | 0     | 0   | 0     | 0    | 0       | 0     | 1     |
| VirusTotal Jujubox     | Malicious | 1     | 0   | 0     | 0    | 0       | 0     | 4     |
| Zenbox                 | Malicious | 2     | 6   | 0     | 0    | 0       | 0     | 4     |

Search sha256 of the malicious at Virustotal.

```
UDP a83f:8110:30a3:38a3:40a3:48a3:50a3:58a3:53
TCP 23.216.147.76:443
TCP 104.86.182.43:443
TCP 20.99.132.105:443
UDP a83f:8110:0:0:2000:0:0:0:53
UDP a83f:8110:0:0:2800:0:0:0:53
TCP 13.107.39.203:80
UDP a83f:8110:2800:1800:4000:1800:1800:100:53
TCP 20.62.24.77:443
TCP 23.216.147.64:443
UDP a83f:8110:6f6f:6b75:7046:756e:6374:696f:53
```

I get many IP addresses from the Behaviour column. Then, I used ctrl+f to find 23.216 at the page.

There are 3 IP addresses marked. Two of them are very similar to each other. I guess they may be a pair of IP addresses for this question.

Question 9) Using these two gathered IPs, check to see if there is any activity from them in Splunk, which there might not be! What is the number of events per IP where the address is mentioned ANYWHERE in a log? (Format: IP1EventCount, IP2EventCount) (3 points)

0,0

Correct! ✓

The screenshot shows the Splunk Enterprise web interface. At the top, the navigation bar includes the Splunk logo, the word 'enterprise', and a dropdown menu for 'Apps'. Below this is a secondary navigation bar with links for 'Search', 'Analytics', 'Datasets', 'Reports', 'Alerts', and 'Dashboards'. The 'Search' link is highlighted with a green underline. The main content area has a light gray header with the text 'New Search'. Below this is a search input field containing the query '1 \* "23.216.147"'. Underneath the search bar, a status line indicates '0 events (before 5/29/26 1:42:52.000 AM)' and 'No Event Sampling' with a dropdown arrow. Below the status line is a row of tabs: 'Events (0)', 'Patterns', 'Statistics', and 'Visualization'. The 'Events (0)' tab is selected and highlighted with a blue underline. The main content area is mostly empty, with the text 'No results found.' centered at the bottom.

There is no item about ip address "23.216.147".

**Question 10) At what time was this file uploaded to the web server? (Use 'timestamp' value) (Format: YYYY-MM-DDTHH:MM:SS) (4 points)**

2016-08-10T21:52:47

Correct! ✓

The screenshot displays the VirusShare search results for file 3791.exe. The interface includes a search bar at the top with the query '3791.exe' and a 'Sort' button. Below the search bar, there are tabs for 'Events', 'Patterns', 'Statistics', and 'Visualization'. The 'Events' tab is active, showing a list of events. The selected event is a 'Process' event at 8/10/16 9:52:45:000 PM. The event details show the file was executed by a user named 'user' from a source IP of 192.168.250.1. The event type is 'Process' and the action is 'Execute'. The event details also show the file was executed from a source IP of 192.168.250.1 and the action was 'Execute'.

Search the malicious executable 3791.exe and present them in chronological order. I got the item logged 'upload successfully' for 3791.exe. From this log item, I got the answer in timestamp tag.

Mozilla/5.0 (Windows NT 6.1; WOW64; Tride

```

170106
9:52:47.035 PM
{"endtime": "2016-08-10T21:52:47.5555Z", "timestamp": "2016-08-10T21:52:45.437455Z", "accept": "text/html, application/xhtml+xml, */*", "accept_language": "en-US", "ack_packets_in": 1, "ack_s": "77896", "bytes_in": 77648, "bytes_out": 248, "c_ip": "40.80.148.42", "cached": "0", "capture_hostname": "demo-01", "client_rtt": "0", "client_rtt_packets": "0", "client_rtt_ack": "0", "connection_type": "Ks", "os": "Windows", "os_version": "6.0", "path": "C:\\form-data; name='userfile[0]'; filename='3791.exe';", "form-data": "name='userfile[1]'; filename='agent.php'", "form-data": "name='userfile[2]'; filename='\\'", "form-data": "name='\\'", "form-data": "name='\\'", "form-data": "name='userfile[4]'; filename='\\'", "form-data": "name='userfile[5]'; filename='\\'", "form-data": "name='userfile[6]'; filename='\\'", "form-data": "name='option[]';", "form-data": "name='action[]';", "form-data": "name='dir[]';", "form-data": "name='requestType[]";, "form-data": "name='confirm[]";, "cookie": "77598a3465c906161e24mh1tlik3he7ua23";, "cs_cache_content": "no-cache", "cs_content_length": 77045, "cs_content_type": "multipart/form-data; boundary="7e0e4c220990", "cs_version": "1.1", "time": 1948686, "data_packets_out": 55, "data_packets_out_1": "dest_content": "{'action': 'upload', 'message': 'Upload successful!', 'error': 'Upload successful!', 'success': true}";, "dest_headers": "Content-Type: text/html; r/nServer: Microsoft-IIS/8.5/r/nPowered-By: PHP/5.5.38/r/nDate: Wed, 10 Aug 2016 21:52:47 GMT/r/nContent-Length: 94/r/n/r/n", "dest_ip": "192.168.250.70", "dest_ip_1": "dest_port": 80, "duplicate_packets_in": 52, "duplicate_packets_out": 1, "html_comment": "HTTP/1.1 200 OK", "http": 1, "http_content_length": 94, "http_content_type": "text/html", "http_method": "POST", "is_really_outbound": true, "ip": "192.168.250.70", "ip_1": "ip_2": "192.168.250.70", "ip_3": "192.168.250.70", "ip_4": "192.168.250.70", "ip_5": "192.168.250.70", "ip_6": "192.168.250.70", "ip_7": "192.168.250.70", "ip_8": "192.168.250.70", "ip_9": "192.168.250.70", "ip_10": "192.168.250.70", "ip_11": "192.168.250.70", "ip_12": "192.168.250.70", "ip_13": "192.168.250.70", "ip_14": "192.168.250.70", "ip_15": "192.168.250.70", "ip_16": "192.168.250.70", "ip_17": "192.168.250.70", "ip_18": "192.168.250.70", "ip_19": "192.168.250.70", "ip_20": "192.168.250.70", "ip_21": "192.168.250.70", "ip_22": "192.168.250.70", "ip_23": "192.168.250.70", "ip_24": "192.168.250.70", "ip_25": "192.168.250.70", "ip_26": "192.168.250.70", "ip_27": "192.168.250.70", "ip_28": "192.168.250.70", "ip_29": "192.168.250.70", "ip_30": "192.168.250.70", "ip_31": "192.168.250.70", "ip_32": "192.168.250.70", "ip_33": "192.168.250.70", "ip_34": "192.168.250.70", "ip_35": "192.168.250.70", "ip_36": "192.168.250.70", "ip_37": "192.168.250.70", "ip_38": "192.168.250.70", "ip_39": "192.168.250.70", "ip_40": "192.168.250.70", "ip_41": "192.168.250.70", "ip_42": "192.168.250.70", "ip_43": "192.168.250.70", "ip_44": "192.168.250.70", "ip_45": "192.168.250.70", "ip_46": "192.168.250.70", "ip_47": "192.168.250.70", "ip_48": "192.168.250.70", "ip_49": "192.168.250.70", "ip_50": "192.168.250.70", "ip_51": "192.168.250.70", "ip_52": "192.168.250.70", "ip_53": "192.168.250.70", "ip_54": "192.168.250.70", "ip_55": "192.168.250.70", "ip_56": "192.168.250.70", "ip_57": "192.168.250.70", "ip_58": "192.168.250.70", "ip_59": "192.168.250.70", "ip_60": "192.168.250.70", "ip_61": "192.168.250.70", "ip_62": "192.168.250.70", "ip_63": "192.168.250.70", "ip_64": "192.168.250.70", "ip_65": "192.168.250.70", "ip_66": "192.168.250.70", "ip_67": "192.168.250.70", "ip_68": "192.168.250.70", "ip_69": "192.168.250.70", "ip_70": "192.168.250.70", "ip_71": "192.168.250.70", "ip_72": "192.168.250.70", "ip_73": "192.168.250.70", "ip_74": "192.168.250.70", "ip_75": "192.168.250.70", "ip_76": "192.168.250.70", "ip_77": "192.168.250.70", "ip_78": "192.168.250.70", "ip_79": "192.168.250.70", "ip_80": "192.168.250.70", "ip_81": "192.168.250.70", "ip_82": "192.168.250.70", "ip_83": "192.168.250.70", "ip_84": "192.168.250.70", "ip_85": "192.168.250.70", "ip_86": "192.168.250.70", "ip_87": "192.168.250.70", "ip_88": "192.168.250.70", "ip_89": "192.168.250.70", "ip_90": "192.168.250.70", "ip_91": "192.168.250.70", "ip_92": "192.168.250.70", "ip_93": "192.168.250.70", "ip_94": "192.168.250.70", "ip_95": "192.168.250.70", "ip_96": "192.168.250.70", "ip_97": "192.168.250.70", "ip_98": "192.168.250.70", "ip_99": "192.168.250.70", "ip_100": "192.168.250.70", "ip_101": "192.168.250.70", "ip_102": "192.168.250.70", "ip_103": "192.168.250.70", "ip_104": "192.168.250.70", "ip_105": "192.168.250.70", "ip_106": "192.168.250.70", "ip_107": "192.168.250.70", "ip_108": "192.168.250.70", "ip_109": "192.168.250.70", "ip_110": "192.168.250.70", "ip_111": "192.168.250.70", "ip_112": "192.168.250.70", "ip_113": "192.168.250.70", "ip_114": "192.168.250.70", "ip_115": "192.168.250.70", "ip_116": "192.168.250.70", "ip_117": "192.168.250.70", "ip_118": "192.168.250.70", "ip_119": "192.168.250.70", "ip_120": "192.168.250.70", "ip_121": "192.168.250.70", "ip_122": "192.168.250.70", "ip_123": "192.168.250.70", "ip_124": "192.168.250.70", "ip_125": "192.168.250.70", "ip_126": "192.168.250.70", "ip_127": "192.168.250.70", "ip_128": "192.168.250.70", "ip_129": "192.168.250.70", "ip_130": "192.168.250.70", "ip_131": "192.168.250.70", "ip_132": "192.168.250.70", "ip_133": "192.168.250.70", "ip_134": "192.168.250.70", "ip_135": "192.168.250.70", "ip_136": "192.168.250.70", "ip_137": "192.168.250.70", "ip_138": "192.168.250.70", "ip_139": "192.168.250.70", "ip_140": "192.168.250.70", "ip_141": "192.168.250.70", "ip_142": "192.168.250.70", "ip_143": "192.168.250.70", "ip_144": "192.168.250.70", "ip_145": "192.168.250.70", "ip_146": "192.168.250.70", "ip_147": "192.168.250.70", "ip_148": "192.168.250.70", "ip_149": "192.168.250.70", "ip_150": "192.168.250.70", "ip_15
```

**Question 12) What URI received a POST request from the attacker, in order to upload the file? (Format: /path/to/something) (4 points)**

</joomla/administrator/index.php>

Correct! ✓

```
src_ip: 40.80.148.42
src_mac: 08:5B:0E:93:92:AF
src_port: 49490
status: 200
time_taken: 1725267
timestamp: 2016-08-10T21:52:47.246941Z
transport: tcp
uri: /joomla/administrator/index.php
uri_path: /joomla/administrator/index.php
```

[Show as raw text](#)

```
host = splunk-02      source = stream:http      sourcetype = stream:http
```

From the search result of '3791.exe' and filter with 'http\_method=POST', I got the answer in the tag 'Uri'.

40.80.148.42

```
{ "endtime": "2016-08-10T21:52:47.035555Z", "timestamp": "2016-08-10T21:52:45.437445Z", "accept": "text/html, application/xhtml+xml, */*", "as": "77896", "bytes_in": 77648, "bytes_out": 248, "c_ip": "40.89.148.42", "cached": 0, "capture_hostname": "demo-01", "client_rtt": 0, "client_rtt_pac": 0, "position": [{"form-data; name=\"userfile[0]\"; filename=\"3791.exe\"\", \"form-data; name=\"userfile[1]\"; filename=\"agent.php\"\", \"form-data; [3]\"; filename=\"\\\"\", \"form-data; name=\"userfile[4]\"; filename=\"\\\"\", \"form-data; name=\"userfile[5]\"; filename=\"\\\"\", \"form-data; na\\\"\", \"form-data; name=\"option\"\", \"form-data; name=\"action\"\", \"form-data; name=\"dir\"\", \"form-data; name=\"requestType\"\", \"form-data;
```

**Question 14) We need to understand if any of our network defenses have detected this activity, or if we're completely blind. Use one of the retrieved indicators to search the logs to see if anything has flagged this file as being malicious. Provide any timestamp retrieved from a relevant log to show evidence of some kind of alert or notification (Format: YYYY-MM-DD HH:MM:SS) (5 points)**

2016-08-10 15:52:45

Correct! ✓

The screenshot displays the VirusShare interface for a specific file, 3791.exe. The top navigation bar includes a search bar, a filter for 'All time', and a 'Smart Mode' toggle. Below this, a summary bar indicates '76 events (before 5/29/26 3:05:12:000 AM)' and 'No Event Sampling'. The main area is divided into a 'Format Timeline' section with a 'Zoom Out' button and a 'Zoom to Selection' button, and a 'List' section with a 'Format' button and a '20 Per Page' setting. The timeline itself shows a single event at 8/10/16 9:52:45.000 PM. The event details are displayed in a table with columns for 'Time' and 'Event'. The event is a network connection from 192.168.259.1 to 192.168.259.7 on port 80, with a user-agent of Mozilla/5.0 and a source of source5. The event is categorized as a network connection (type: network) and is associated with the file 3791.exe.

| Time                   | Event                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               |
|------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 8/10/16 9:52:45.000 PM | Aug 10 15:52:45 192.168.259.1 [date=2016-08-10 time=15:52:45 domain=gothan-fortigate device=FGT6804614844725 login=6211088193 type=network subtype=virus eventtype=infected level=notice uid=root* msg=File is infected... action=monitored service=HTTP sessionid=922537 srcip=40.180.142 dstip=192.168.259.7 srcport=49490 dstport=80 dstintf=internal* policyid=26 protos=direction=outgoing filename=3791.exe quars=kip=No-skip virus="K32/Serort.Clr" dtype="virus" ref="http://www.fortinet.com/vel/vm/K32F2Serort.C321r" virussid=1706341 url="http://ireallynotbadman.com/joomla/administrator/index.php?profile=Honeygot-Access?user=1" agent="Mozilla/5.0" analyticscksum="ec78c938d845373ca2a378b9c275971ec4dc4cfe6479dc2b2d04e97cc47fa45d" analyticssubmit=false crscore=90 crlevel=critical host=192.168.250.1 source=udp514 source_type=fortigate_idm |

I noticed that a log is associated with virus detected, so I read more detail about this item.

☐ date ▼ 2016-08-10

☐ time ▼ 15:52:45

So I put the date and time together as an answer to the question.

## Investigate the whole attack chain

- Then, I am going to investigate the other uploaded file, agent.php from the attacker. I search agent.php, and get 837 items. it

New Search

All time

✓ 837 events (before 5/31/26 9:12:58.000 PM)
No Event Sampling ▼
Job ▼
IT
Smart Mode ▼

Events (837)

Patterns

Statistics

Visualization

Format Timeline ▼

Zoom Out

Zoom to Selection

Deselect

1 minute per column

List ▼

Format

20 Per Page ▼

Prev

1

2

3

4

5

6

7

8

Next >

Hide Fields

All Fields

SELECTED FIELDS

a host 4  
 a source 4  
 a sourcetype 4

INTERESTING FIELDS

a accept 100+  
 a accept\_language 100+  
 # ack\_packets\_in 5  
 # ack\_packets\_out 5  
 a action 1  
 a app 4  
 # bytes 100+  
 # bytes\_in 100+  
 # bytes\_out 100+  
 a c\_ip 2  
 # cached 1

Time

Event

8/10/16  
 10:21:34.828 PM  

```

{ [-]
  app_proto: http
  dest_ip: 23.22.63.114
  dest_port: 47517
  event_type: fileinfo
  fileinfo: { [-]
    }
  flow_id: 828689104
  http: { [-]
    }
  in_iface: eth1
  proto: TCP
  src_ip: 192.168.250.70
  src_port: 80
  timestamp: 2016-08-10T16:21:34.828382-0600
}
          
```

Show as raw text

host = source:ids.wanpcrminer-local    source = source:networks/que-ten    sourcetype = source:ids

The earliest item shown attacker used POST request to the victim machine from srcip 40.80.148.42.

The http reference is

“http://vimreallynotbatman.com/vjoomla/administrator/index.php?option=com\_installer”. The file uploaded was agent.php.



< Hide Fields    ≡ All Fields

|   |                        |      |
|---|------------------------|------|
| a | devId                  | 1    |
| a | devname                | 1    |
| a | direction              | 1    |
| a | dstintf                | 1    |
| a | dstip                  | 1    |
| # | dstport                | 1    |
| # | duplicate_packets_in   | 3    |
| # | duplicate_packets_out  | 2    |
| a | dvc                    | 2    |
| a | endtime                | 100+ |
| a | event_type             | 2    |
| a | eventtype              | 5    |
| a | expires                | 1    |
| a | file_name              | 1    |
| a | file_path              | 1    |
| # | flow_id                | 100+ |
| a | ftnt_action            | 2    |
| a | hostname               | 1    |
| a | http.hostname          | 2    |
| a | http.http_content_type | 1    |
| a | http.http_method       | 2    |
| a | http.http_refer        | 100+ |
| a | http.http_user_agent   | 100+ |
| # | http.length            | 14   |
| a | http.protocol          | 1    |
| # | http.status            | 2    |
| a | http.uri               | 3    |
| a | http_comment           | 2    |
| # | http_content_length    | 15   |
| a | http_content_type      | 2    |
| a | http_method            | 2    |
| a | http_protocol          | 1    |
| a | http_referrer          | 100+ |
| a | http_user_agent        | 100+ |
| a | ids_type               | 1    |
| a | in_iface               | 1    |

## http\_referrer

>100 Values, 53.046% of events

Selected

### Reports

Top values

Top values by time

Rare values

Events with this field

| Top 10 Values                                                                                                                                                                       | Count | %      |
|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------|--------|
| http://71.39.18.126/?wNO=-YHXoVu_ZEYvNqELHNxhP692w17zRf                                                                                                                             | 4     | 0.901% |
| http://71.39.18.126/?xC=G85xbe3I-XS8_Q-8jDyz0qaqIr-YHX&Pp=ovU_ZEYvNqELHNxhP692w17zRfE2xD                                                                                            | 4     | 0.901% |
| http://71.39.18.126/joomla/agent.php?wVz=27KDP5Qiyg9WM0nnye_5SLS_LevPhp                                                                                                             | 4     | 0.901% |
| http://translate.googleusercontent.com/translate_c?depth=1&rurl=translate.google.com&sl=auto&tl=en&u=39&usg=1hd3pZQh_gYvorKjPLcunmC00IeiUFebJE                                      | 4     | 0.901% |
| http://www.google.com.mx/url?sa=t&rct=j&q=39&source=web&cd=210&ved=Cf-p6io6t&url=39.18&ei=_AiFuHyDELmznspXkb0sx&usg=PEos6pgPv-Ka6fZncFhVK0C_pf00lG9-Lv&sig2=oauZOFzhEmW3vUtw0UiWVR  | 4     | 0.901% |
| http://www.google.com.mx/url?sa=t&rct=j&q=39&source=web&cd=210&ved=f-p6io6te&url=39.18&ei=_AiFuHyDELmznspXkb0sxP&usg=Eos6pgPv-Ka6fZncFhVK0C_pf00lG9-Lvo&sig2=auZOFzhEmW3vUtw0UiWVRX | 4     | 0.901% |
| http://www.google.ge/url?sa=t&rct=j&source=web&cd=999&ved=G85xbe3I-&ei=XS8_Q-8jDyz0qaqIr-YHXo&usg=Vu_ZEYvNqELHNxhP692w17zRfE2xDCF-p6                                                | 4     | 0.901% |
| http://71.39.18.126/?BVw=4c4094q3Qx7NjAFxeaak                                                                                                                                       | 3     | 0.676% |
| http://71.39.18.126/?wNO=F9rGRZA084mydcVAa4cX                                                                                                                                       | 3     | 0.676% |

|   |                        |      |
|---|------------------------|------|
| a | http.http_content_type | 1    |
| a | http.http_method       | 2    |
| a | http.http_refer        | 100+ |
| a | http.http_user_agent   | 100+ |
| # | http.length            | 14   |
| a | http.protocol          | 1    |
| # | http.status            | 2    |
| a | http.uri               | 3    |
| a | http_comment           | 2    |
| # | http_content_length    | 15   |
| a | http_content_type      | 2    |
| a | http_method            | 2    |
| a | http_protocol          | 1    |
| a | http_referrer          | 100+ |
| a | http_user_agent        | 100+ |
| a | ids_type               | 1    |

## http.uri

3 Values, 29.63% of events

Selected

### Reports

Top values

Top values by time

Rare values

Events with this field

| Values                                                            | Count | %       |
|-------------------------------------------------------------------|-------|---------|
| /joomla/agent.php                                                 | 246   | 99.194% |
| /joomla/administrator/index.php                                   | 1     | 0.403%  |
| /joomla/administrator/index.php?option=com_installer&view=install | 1     | 0.403%  |

I do some research about Joomla. It is the second most popular **self-hosted Content Management System (CMS)** in the world. So, I guess the attacker have visited the Joomla Website backend system.

|   |                           |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   |
|---|---------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| > | 8/10/16<br>9:55:36.000 PM | Aug 10 15:55:36 192.168.250.1 date=2016-08-10 time=15:55:36 devname=gotham-fortigate devid=FGT6004614044725 logid=0317013312 type=utm subtype=webfilter eventtype=ftgd_allow level=notice vd=root policyid=26 sessionid=925003 user="" srcip=23.22.63.114 srcport=47367 dstip=192.168.250.70 dstport=80 dstintf=internal3 proto=6 service=HTTP hostname=71.39.18.126 profile=flow-monitor-all action=passthrough retype=direct url=/joomla/agent.php sentbyte=517 rcvbyte=0 direction=N/A msg="URL belongs to an allowed category in policy" method=domain cat=0 catdesc=Unrated host = 192.168.250.1 source = udp/514 sourcetype = fortigate_utm |
| > | 8/10/16<br>9:55:36.000 PM | Aug 10 15:55:36 192.168.250.1 date=2016-08-10 time=15:55:36 devname=gotham-fortigate devid=FGT6004614044725 logid=0317013312 type=utm subtype=webfilter eventtype=ftgd_allow level=notice vd=root policyid=26 sessionid=925002 user="" srcip=23.22.63.114 srcport=47366 dstip=192.168.250.70 dstport=80 dstintf=internal3 proto=6 service=HTTP hostname=71.39.18.126 profile=flow-monitor-all action=passthrough retype=direct url=/joomla/agent.php sentbyte=431 rcvbyte=0 direction=N/A msg="URL belongs to an allowed category in policy" method=domain cat=0 catdesc=Unrated host = 192.168.250.1 source = udp/514 sourcetype = fortigate_utm |
| > | 8/10/16<br>9:55:36.000 PM | Aug 10 15:55:36 192.168.250.1 date=2016-08-10 time=15:55:36 devname=gotham-fortigate devid=FGT6004614044725 logid=0317013312 type=utm subtype=webfilter eventtype=ftgd_allow level=notice vd=root policyid=26 sessionid=925001 user="" srcip=23.22.63.114 srcport=47365 dstip=192.168.250.70 dstport=80 dstintf=internal3 proto=6 service=HTTP hostname=71.39.18.126 profile=flow-monitor-all action=passthrough retype=direct url=/joomla/agent.php sentbyte=482 rcvbyte=0 direction=N/A msg="URL belongs to an allowed category in policy" method=domain cat=0 catdesc=Unrated host = 192.168.250.1 source = udp/514 sourcetype = fortigate_utm |

- From this result about Agent.php, I learned that the public IP address of the website run by the victim server is 71.39.18.126 and internal ip address is 192.168.250.70.
- About The virus detected on 08-10-2016@15:52:45, I got a result on Google, which explains where 3791.exe came from.

"W32/Swrort.C!tr" (detected as [Trojan:Win32/Swrort](#) by Microsoft and [Trojan.Swrort](#) by Malwarebytes) is a severe Trojan and backdoor that allows unauthorized hackers to access your PC, steal data, and download additional malicious files. [Malwarebytes +1](#)

## What This Trojan Does

- **Backdoor Access:** Opens your system to remote attackers, allowing them to take control or infiltrate your network.
- **Malware Dropper:** Downloads and installs secondary malware (such as ransomware or spyware) silently.
- **System Disruption:** Often hides in system files, creating sluggish performance, random crashes, and blocking Task Manager or antivirus updates. [Microsoft +4](#)

```
server_rtt: 53984
server_rtt_packets: 1
server_rtt_sum: 53984
site: imreallynotbatman.com
src_content: username=admin&task=login&return=aw5kZXgucGhw&option=com_login&passwd=12345678&9d873c2becd118318849d13cf18b60ff=1
src_headers: POST /joomla/administrator/index.php HTTP/1.1
Accept-Encoding: identity
Content-Length: 113
Host: imreallynotbatman.com
User-Agent: Python-urllib/2.7
Connection: close
Cookie: 7598a3465c906161e060ac551a9e0276=p5iqb7foa0q92mk0tnr2i8lnc0
Content-Type: application/x-www-form-urlencoded

src_ip: 23.22.63.114
src_mac: 08:5B:0E:93:92:AF
src_port: 46183
status: 303
time_taken: 11072571
timestamp: 2016-08-10T21:45:10.253339Z
transport: tcp
uri: /joomla/administrator/index.php
uri_path: /joomla/administrator/index.php
```

### Investigating the AWS service IP address 23.22.63.114.

- I get many items about POST requests from 23.22.63.114 --> 192.168.250.70:80 with credential form data. And it records that useragent: Python-urllib/2.7 [**Urllib or urllib2 standard libraries in Python 2.7 when making HTTP requests. --- google**]

Hide Fields

All Fields

# linecount 1

a location 1

# missing\_packets\_in 1

# missing\_packets\_out 2

a network\_interface 1

# packets\_in 2

# packets\_out 2

a product 1

a proto 1

a punct 2

# reply\_time 100+

a request 1

# request\_ack\_time 100+

# request\_time 1

# response\_ack\_time 100+

# response\_time 1

a sc\_date 50

a server 1

# server\_rtt 100+

# server\_rtt\_packets 2

# server\_rtt\_sum 100+

a site 1

a splunk\_server 1

a src 2

a src\_content 100+

a src\_headers 100+

a src\_ip 2

a src\_mac 1

# src\_port 100+

# status 1

a tag 1

a tag::eventtype 1

# time\_taken 100+

# timeendpos 2

a timestamp 100+

# timestartpos 2

a transport 2

a url 1

a url\_path 1

a url 1

a vendor 1

src\_content

>100 Values, 25.015% of events

Selected

Reports

Top values

Top values by time

Rare values

Events with this field

| Top 10 Values                                                                                                     | Count | %      |
|-------------------------------------------------------------------------------------------------------------------|-------|--------|
| username=admin&0960d493674eb04861bd64da9b662118=1&task=login&return=aW5kZXgucGhw&option=com_login&passwd=arthur   | 1     | 0.243% |
| username=admin&0edae02d7478dfb41641700ef384807a=1&task=login&return=aW5kZXgucGhw&option=com_login&passwd=bigdaddy | 1     | 0.243% |
| username=admin&115c3aa6072f4b02b4354909431510f6=1&task=login&return=aW5kZXgucGhw&option=com_login&passwd=blazer   | 1     | 0.243% |
| username=admin&12c709bcc2e14d5a015f054d18d36537=1&task=login&return=aW5kZXgucGhw&option=com_login&passwd=fire     | 1     | 0.243% |
| username=admin&2a2ddf97716c1d1e9da21cdaf82b231e=1&task=login&return=aW5kZXgucGhw&option=com_login&passwd=777777   | 1     | 0.243% |
| username=admin&2c340c4e46444ba249ff7e599e6dfa52=1&task=login&return=aW5kZXgucGhw&option=com_login&passwd=flower   | 1     | 0.243% |
| username=admin&32c15329bc3f78039869bb3bf17c28a6=1&task=login&return=aW5kZXgucGhw&option=com_login&passwd=zzzzzz   | 1     | 0.243% |
| username=admin&33fb6e7c85dfd116036c59ddf617d2f1=1&task=login&                                                     | 1     | 0.243% |

Brute force attempts happened on username: admin.

## Investigate the IP address 40.80.148.42

- search Get request

8/10/16

10:21:18.468 PM

```

{ [-]
  dest_ip: 192.168.250.70
  dest_port: 80
  event_type: http
  flow_id: 3318498196
  http: { [+]
  }
  in_iface: eth1
  proto: TCP
  src_ip: 40.80.148.42
  src_port: 49501
  timestamp: 2016-08-10T16:21:18.468110-0600
  tx_id: 1
}

```

Show as raw text

Event Actions ▾

| Type     | <input checked="" type="checkbox"/> | Field           | Value                           | Actions |
|----------|-------------------------------------|-----------------|---------------------------------|---------|
| Selected | <input checked="" type="checkbox"/> | host ▾          | suricata-ids.waynecorpinc.local | ▾       |
|          | <input checked="" type="checkbox"/> | source ▾        | /var/log/suricata/eve.json      | ▾       |
|          | <input checked="" type="checkbox"/> | sourcetype ▾    | suricata                        | ▾       |
| Event    | <input type="checkbox"/>            | bytes ▾         | 16684                           | ▾       |
|          | <input type="checkbox"/>            | dest ▾          | imreallynotbatman.com           | ▾       |
|          | <input type="checkbox"/>            | dest_ip ▾       | 192.168.250.70                  | ▾       |
|          | <input type="checkbox"/>            | dest_port ▾     | 80                              | ▾       |
|          | <input type="checkbox"/>            | dvc ▾           | suricata-ids.waynecorpinc.local | ▾       |
|          | <input type="checkbox"/>            | event_type ▾    | http                            | ▾       |
|          | <input type="checkbox"/>            | eventtype ▾     | suricata_eve_http ( web )       | ▾       |
|          | <input type="checkbox"/>            | flow_id ▾       | 3318498196                      | ▾       |
|          | <input type="checkbox"/>            | http.hostname ▾ | imreallynotbatman.com           | ▾       |

Source ip → Destination ip is 192.168.250.70.

8/10/16  
10:18:12.756 PM

```

app_proto: http
dest_ip: 40.80.148.42
dest_port: 49494
event_type: fileinfo
fileinfo: { [+]
}
flow_id: 10112440
http: { [+]
}
in_iface: eth1
proto: TCP
src_ip: 192.168.250.70
src_port: 80
timestamp: 2016-08-10T16:18:12.756355-0600

```

Show as raw text

Event Actions ▼

| Type     | Field       | Value                           | Actions |
|----------|-------------|---------------------------------|---------|
| Selected | host        | suricata-ids.waynecorpinc.local | ▼       |
|          | source      | /var/log/suricata/eve.json      | ▼       |
|          | sourcetype  | suricata                        | ▼       |
| Event    | app         | http                            | ▼       |
|          | app_proto   | http                            | ▼       |
|          | bytes       | 828                             | ▼       |
|          | dest        | imreallynotbatman.com           | ▼       |
|          | dest_ip     | 40.80.148.42                    | ▼       |
|          | dest_port   | 49494                           | ▼       |
|          | dvc         | suricata-ids.waynecorpinc.local | ▼       |
|          | event_type  | fileinfo                        | ▼       |
|          | file_size   | 828                             | ▼       |
|          | file_state  | CLOSED                          | ▼       |
|          | file_stored | false                           | ▼       |

Source ip 192.168.250.70 → 40. 80.148.42. Do not confuse both of the logs, Suricata records the connection of both sides. Web servers never send requests to clients, but respond to the request sent by clients and share the HTTP request method on both sides of the connection.

- I have found that 3791.exe was uploaded. Then I search "EventCode=1" for the

execution of the executable. I got 5 items. From 9:56:18 ~10:08:13. The

commandline is "cmd.exe /c "3791.exe 2>&1"

8/10/16  
9:56:18.000 PM

```

<Event xmlns="http://schemas.microsoft.com/win/2004/08/events/event"><System><Provider Name="Microsoft-Windows-Sysmon" Guid="{5770385F-C22A-43E0-BF4C-06F5638FFBD3}" /><EventID>1</EventID><Version>5</Version>
<Level>4</Level><Task>1</Task><OpCode>0</OpCode><Keywords>0x8000000000000000</Keywords><TimeCreated SystemTime="2016-08-10T21:56:18.142461700Z" /><EventRecordID>428881</EventRecordID><Correlation></Correlation></Execution
ProcessID="1296" ThreadID="1416" /><Channel>Microsoft-Windows-Sysmon/Operational</Channel><Computer>well149srv.waynecorpinc.local</Computer><Security UserID="S-1-5-18" /></System><EventData><Data Name="UtcTime"
">2016-08-10 21:56:18.142</Data><Data Name="ProcessGuid">{E50808EA-A302-57AB-0000-00102E63C301}</Data><Data Name="ProcessId">2896</Data><Data Name="Image">C:\Windows\SysWOW64\cmd.exe</Data><Data Name="Command
Line">cmd.exe /c "3791.exe 2>&1"</Data><Data Name="CurrentDirectory">C:\inetpub\wwwroot\joomla\</Data><Data Name="User">NT AUTHORITY\SYSTEM</Data><Data Name="LogonGuid">{E50808EA-219E-57AA-0000-0020E303
0000}</Data><Data Name="LogonId">0</Data><Data Name="TerminalSessionId">0</Data><Data Name="IntegrityLevel">High</Data><Data Name="Hashes">SHA1=F5CDBA078EA7D2B40A29F21F9E29AF23341C59C, MD5=55A1D4FACD7B33
3F76C4142CD42D34BA, SHA256=E1A80E61FB1BAF0A629D34BAEE6F0F00E8337BF6CED9F4B3A89B1C23D91BA, INPHASH=5B13496CE22690F7785A486B1BBF93CD3</Data><Data Name="ParentProcessGuid">{E50808EA-A048-374B-0000-00107EEA70
1}</Data><Data Name="ParentProcessId">1208</Data><Data Name="ParentImage">C:\Program Files (x86)\VHP\vs5.5\php-cgi.exe</Data><Data Name="ParentCommandLine">C:\Program Files (x86)\VHP\vs5.5\php-cgi.exe</Data>
</EventData></Event>

```

host = well149srv | source = WinEventLog:Microsoft-Windows-Sysmon/Operational | sourcetype = xmlwineventlog

From the picture above, I know the 3791.exe runs by cmd command. And the parent commandline of cmd is php-cgi.exe. So I can guess a php webshell has been built and has the function and access to run cmd.exe. The agent.php uploaded by the attacker may be the suspicious php file. By analyzing the behaviors of agent.php, I have much evidence about attacker request agent.php with Http GET/POST requests which used to test and execute webshell commandline.